

Міністерство освіти і науки України
Національний технічний університет України «Київський політехнічний
інститут імені
Ігоря Сікорського»
Фізико-технічний інститут

Лабораторна робота №3
Реалізація смарт-контракту або анонімної криптовалюти

Дисципліна: «Блокчейн та децентралізовані системи»
Виконав: ФЕ-51мп Руденко Іван

Мета роботи: Дослідження вимог OWASP (безпека web-додатків) та складання аналогічних вимог для обраної системи децентралізованих додатків.

Список вимог OWASP Top 10 до безпеки Web-додатків

- Broken Access Control — неправильна або відсутня перевірка прав доступу.
- Cryptographic Failures — слабе або відсутнє шифрування.
- Injection — SQL, OS або інші ін'єкції через недовірені дані.
- Insecure Design — поганий проект з точки зору безпеки.
- Security Misconfiguration — неправильні налаштування безпеки.
- Vulnerable and Outdated Components — небезпечні або застарілі сторонні компоненти.
- Identification and Authentication Failures — проблеми з ідентифікацією та автентифікацією.
- Software and Data Integrity Failures — незахищене оновлення або зміна коду.
- Security Logging and Monitoring Failures — відсутність логування та моніторингу.
- Server-Side Request Forgery (SSRF) — сервер виконує шкідливі зовнішні запити.

Аналогічні вимоги для децентралізованого додатку (на прикладі Uniswap v3)

Uniswap v3 — це децентралізований протокол обміну tokenів на Ethereum, що реалізує автоматичний маркет-мейкер (AMM) з концентрованою ліквідністю. Логіка повністю зосереджена у смарт-контрактах мовою Solidity, без централізованого сервера.

1. Несправна перевірка доступу (Broken Access Control)

Контракти Uniswap v3 містять функції управління (setFeeProtocol, collectProtocol), доступні лише для власника (factory owner). У ранніх версіях децентралізованих протоколів відсутність чи помилка у перевірці owner дозволяла б будь-якому зловмисникові змінити комісії або вивести накопичений протокольний прибуток.

Рішення:

- Перевірка msg.sender через модифікатор onlyOwner або власний guard на рівні кожної привілейованої функції.
- Розподіл адміністративних повноважень між timelock-контрактом та governance DAO (Uniswap використовує Governor Bravo).
- Мінімізація кількості адміністративних функцій за принципом мінімальних привілеїв.

2. Слабке або відсутнє шифрування (Cryptographic Failures)

Всі транзакції на Ethereum є публічними. У контексті Uniswap це означає, що великі свопи видимі у mempool до включення в блок. Зловмисники використовують цю інформацію для sandwich-атак: розміщують свою транзакцію перед і після жертви, отримуючи прибуток за рахунок зміни ціни.

Рішення:

- Параметр `amountOutMinimum` при виклику `swap` — захист від надмірного `slippage`; транзакція відхиляється, якщо отримана сума менша за поріг.
- Використання MEV-захисних RPC-провайдерів (Flashbots Protect, MEV Blocker) для приватної трансляції транзакцій.
- `Deadline`-параметр у `swap`-транзакціях запобігає виконанню застарілих транзакцій за несприятливим курсом.

3. Ін'єкції (Injection)

У контексті Uniswap небезпечна ситуація виникає при взаємодії з нестандартними ERC-20 токенами: контракт-токен може реалізувати `callback` у функції `transfer()`, що при необережному використанні призводить до `reentrancy`-атаки (аналог ін'єкції в EVM-середовищі).

Рішення:

- Використання `lock`-мютексу (`reentrancy guard`) — модифікатор, що встановлює прапорець `locked` і відхиляє повторні виклики під час виконання.
- Перевірка відповідності адрес токенів через `whitelist` або реєстр відомих безпечних токенів.
- Використання `SafeERC20` з `OpenZeppelin` для захисту від нестандартних `transfer/approve` реалізацій.

4. Поганий проект з точки зору безпеки (Insecure Design)

АММ-протоколи вразливі до атак через маніпуляцію ціною у межах одного блоку (`price oracle manipulation`). Якщо протокол використовує `spot`-ціну з пулу Uniswap як оракул — зловмисник може через `flash loan` тимчасово змістити ціну та отримати незаслужену вигоду.

Рішення:

- Uniswap v3 надає TWAP (Time-Weighted Average Price) оракул, що усереднює ціну за вказаний проміжок часу. Маніпуляція TWAP потребує утримання ціни протягом багатьох блоків, що економічно не вигідно.
- Проведення `threat modeling` перед запуском нових пулів або розширення функціональності.
- Незалежний аудит кожного нового смарт-контракту перед деплоєм у `mainnet`.

5. Невірні налаштування безпеки (Security Misconfiguration)

Неправильні початкові параметри пулів — некоректний tick spacing, завищені fee tiers, активовані debug-хуки — можуть призвести до неоптимального розподілу ліквідності або уразливості до маніпуляцій.

Рішення:

- Ретельна перевірка параметрів на тестовій мережі (Sepolia) перед деплоєм у mainnet.
- Вимкнення всіх адміністративних функцій та тестових hooks після завершення розробки.
- Аудит конфігурації fee protocol split перед активацією в governance.

6. Небезпечні сторонні компоненти (Vulnerable and Outdated Components)

Uniswap залежить від бібліотек OpenZeppelin, Chainlink-оракулів та власних математичних бібліотек (FullMath, TickMath). Вразливість у будь-якій залежності може компрометувати весь протокол.

Рішення:

- Фіксація версій всіх залежностей у package.json та регулярна перевірка через npm audit або Slither.
- Збереження власних копій критичних бібліотек у репозиторії (vendor lock) для захисту від supply chain атак.
- Моніторинг security bulletins від OpenZeppelin та інших постачальників.

7. Проблеми з автентифікацією (Identification and Authentication Failures)

Автентифікація у Uniswap — виключно через підпис транзакцій приватним ключем. Відсутність nonce або некоректна його перевірка відкриває можливість для replay-атак: зломисник повторно відправляє підписану транзакцію в іншій мережі або після зміни стану.

Рішення:

- Використання EIP-712 для структурованого підпису даних — запобігає підміні контексту підпису.
- Перевірка nonce та chainId у permit-функціях токенів (ERC-20 Permit, EIP-2612).
- Рекомендація використовувати апаратні гаманці (Ledger, Trezor) для зберігання ключів великих позицій.

8. Незахищене оновлення коду (Software and Data Integrity Failures)

Якщо контракти Uniswap мають механізм оновлення (proxy pattern), компрометація ключа адміністратора дозволяє підмінити логіку на шкідливу.

Uniswap v3 навмисно використовує незмінні контракти (immutable), але governance-контракти оновлювані.

Рішення:

- Встановлення timelock не менше 7 днів для будь-яких оновлень через Timelock Controller.
- Вимога кворуму UNI-токенів у governance перед виконанням пропозиції.
- Публікація коду оновлення для громадського аудиту за 14+ днів до виконання.

9. Відсутність логування та моніторингу (Security Logging and Monitoring Failures)

Більшість атак на DeFi-протоколи (flash loan атаки, маніпуляції оракулами) завершуються за 1–3 блоки (12–36 секунд). Без автоматизованого моніторингу вчасна реакція неможлива.

Рішення:

- Інтеграція з Forta Network — децентралізована мережа детекторів аномальних транзакцій, що спрацьовує в реальному часі.
- Логування критичних подій через Ethereum events: Swap, Mint, Burn, Collect — дозволяє відстежувати аномальні обсяги.
- Впровадження механізму Pause (успадкованого від OpenZeppelin) для екстреного призупинення при виявленні атаки.

10. Серверне підроблення запитів (SSRF — адаптація для DeFi)

Смарт-контракти Uniswap безпосередньо не виконують HTTP-запити, але frontend-частина (app.uniswap.org) взаємодіє з RPC-провайдерами, subgraph API (The Graph) та price API. Компрометація цих зовнішніх сервісів може призвести до відображення хибних даних користувачу та спонукати його до невигідних транзакцій.

Рішення:

- Верифікація всіх даних безпосередньо через on-chain виклики смарт-контракту, а не лише через API.
- Whitelist дозволених RPC-ендпоінтів та перевірка цілісності відповідей через підпис.
- Використання Content Security Policy (CSP) на frontend для запобігання підміні скриптів.

Висновок

Принципи OWASP Top 10 є повністю актуальними для децентралізованих додатків, однак кожна категорія вимагає переосмислення відповідно до специфіки блокчейн-середовища. Ключова відмінність від традиційних web-додатків: помилки у смарт-контрактах є незворотними — транзакції в блокчейні

не можна скасувати, а втрачені кошти практично неможливо повернути без згоди спільноти.

Для Uniswap v3 найбільш критичними є загрози, пов'язані з некоректним контролем доступу до governance-функцій, маніпуляцією цінами через flash loan атаки та вразливістю frontend до компрометації зовнішніх API. Саме тому поєднання on-chain захисту (timelock, multisig, TWAP-оракули) з off-chain моніторингом (Forta, OpenZeppelin Defender) є необхідною умовою безпечної роботи DeFi-протоколу.